

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

En relación con los controles implementados para la gestión de inventario y control de activos de hardware, responda lo siguiente:

- a. ¿Qué herramienta es utilizada para identificar los dispositivos de la infraestructura tecnológica qué se conecta a la red? Proporcione evidencia que permita validar los siguientes puntos:
- b. ¿Qué herramienta utiliza para la identificación de direcciones IP de la infraestructura tecnológica? Proporcione evidencia que permita validar los siguientes puntos.
- c. ¿Cómo gestiona las direcciones IP?
- d. ¿Se encuentra segmentada la red interna de forma independiente con los centros de datos?
- e. ¿Con qué frecuencia se actualiza el inventario de activos de infraestructura tecnológica?

Sobre los mecanismos con los que se cuenta para la gestión de inventario y control de activos de software, especifique lo siguiente:

- a. ¿El inventario de software que se tiene es aplicable para toda la empresa o es específico para alguna área?
- b. ¿Se cuenta con procedimientos para la administración de software licenciado? ¿En qué consiste?
- c. ¿Se utiliza software de código abierto? ¿Qué pruebas se realizan para poner en operación dicho software? ¿Todas las áreas lo pueden utilizar una vez aprobado?
- d. ¿Qué área es la encargada de definir, autorizar y formalizar el software que se utilizará en las estaciones de trabajo?
- e. ¿Cómo garantizan que el software utilizado contemple soporte del fabricante?
- f. ¿Cuenta con una herramienta que realice el inventario de software?

Con relación a las actividades implementadas para la gestión continua de vulnerabilidades, responda lo siguiente:

- a. ¿Se cuenta con herramientas para el escaneo de vulnerabilidades?
- b. ¿Se realizan pruebas de penetración?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- c. ¿Qué herramientas se utilizan para la ejecución de pruebas de penetración?
- d. En relación con los hallazgos identificados como resultado de los análisis de vulnerabilidades y pruebas de penetración, responda lo siguiente:
 - ¿Cuál es el proceso de mitigación?
 - ¿Se encuentra documentado y formalizado?
 - ¿Qué seguimiento se da a estas actividades de mitigación?
 - ¿Se generan planes de mitigación?
 - ¿Quién es el responsable de su ejecución y vigilar su cumplimiento?

Sobre el uso controlado de privilegios administrativos, proporcione las siguientes respuestas:

- a. ¿Se cuenta con herramientas para administrar las cuentas de los usuarios?
- b. En relación con la gestión de cuentas con privilegios de administración, responda lo siguiente:
 - ¿Tienen un inventario de cuentas privilegiadas?
 - ¿Se cuenta con procedimientos documentados y formalizados para su gestión?
 - ¿Quién es responsable de autorizar y vigilar el uso de este tipo de cuentas?
- c. ¿Se hace uso de cuentas dedicadas o secundarias para la ejecución de actividades elevadas?
 - ¿Cómo se administran?
 - ¿Quién es responsable de su custodia?
 - ¿En qué sistemas se utilizan y para qué actividades?
 - ¿Cómo se protegen dichas cuentas?
 - ¿Se realiza algún monitoreo sobre dichas cuentas? ¿Quién lo ejecuta? ¿Qué actividades se realizan en caso de detectarse actividades no autorizadas?
- d. ¿Se cuenta con mecanismos para el alertamiento por intentos fallidos de inicio de sesión en la infraestructura tecnológica?
 - ¿Cuál es su alcance?
 - ¿Sobre qué sistemas operan?
 - ¿Considera cuentas privilegiadas?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Quién recibe las alertas?
- ¿Qué actividades se realizan cuando se recibe una alerta? ¿Cómo se registran y documentan?
- e. ¿Se realiza el cambio de contraseñas por defecto en los sistemas?

En relación con los mecanismos implementados para la configuración segura para hardware y software en dispositivos móviles, computadoras portátiles, estaciones de trabajo y servidores especifique lo siguiente:

- a. ¿Cómo se gestionan las licencias de los sistemas operativos y cómo se aseguran de que toda la infraestructura cuenta con licencias originales y actualizadas?
- b. Sobre las imágenes definidas para los equipos e infraestructura de la empresa, responda
 - ¿Cuáles son los criterios que se usan para crear una imagen oficial para los dispositivos de la empresa?
 - ¿Cuántos tipos de imagen se han definido?
 - ¿En qué consisten dichas imágenes? ¿Qué elementos contienen?
 - ¿Se encuentran documentadas y formalizadas?
 - ¿A qué dispositivos son aplicables?
- c. ¿Dónde y cómo se resguardan las imágenes autorizadas por la empresa?
- d. ¿Quién autoriza la imagen predeterminada para los activos y cualquier modificación que se realice a las mismas?
- e. ¿Qué mecanismos que han implementado para la protección de las imágenes y evitar modificaciones no autorizadas?

Sobre las actividades que se ejecutan para el mantenimiento, monitoreo y análisis de logs de auditoría, responda lo siguiente:

- a. ¿Cuántas fuentes de sincronización de tiempo (reloj internacional) se tienen para la infraestructura tecnológica?
- b. ¿Cada cuando se realiza un análisis a las bitácoras de logs?
 - ¿Quién realiza el análisis?
 - ¿Qué tipo de eventos se rastrean?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Cuál es el alcance de dicho análisis?
- ¿Qué actividades se realizan en caso de detectar algún evento no autorizado?
- ¿Qué documentación se genera?
- ¿Existe un procedimiento documentado y formalizado?
- c. ¿Quién tienen acceso a las bitácoras? ¿Cómo se restringe el acceso a las mismas?
¿Cómo se protege la información que contienen?
- d. ¿Cuentan con una herramienta para el análisis automático de los registros generados por los sistemas de la infraestructura tecnológica?
 - ¿Qué herramienta es?
 - ¿Cuál es su configuración?
 - ¿Quién tiene acceso?
 - ¿Qué sistemas, aplicaciones, bases de datos o infraestructura se monitorea?
 - ¿Qué registros se revisan?
 - ¿Genera alertas?
 - ¿Cuáles son los registros o eventos que generan las alertas?
 - ¿Quién recibe esas alertas?
 - ¿Qué actividades se realizan en relación con esas alertas?
 - ¿Qué documentación se genera?
 - ¿Se realizan regularmente ajustes al SIEM para configurar nuevas alertas o disminuir falsos positivos?
 - ¿Con qué frecuencia?
 - ¿Quién realiza, autoriza y supervisa estos ajustes?

Con relación a los mecanismos implementados para la protección de correo electrónico y navegador web, proporcione las siguientes respuestas:

- a. ¿Se han configurado los equipos para restringir la descarga de navegadores de internet diferentes al autorizado por la empresa?
- b. ¿Se han configurado los navegadores de las estaciones de trabajo y equipos de cómputo personales para limitar la activación y desactivación de Plugins? ¿Qué mecanismos se han implementado en relación con la gestión de cookies? ¿Qué otras

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

medidas o configuraciones se han realizado para mantener una configuración segura de los navegadores?

- c. ¿Qué herramientas son utilizadas para detectar correos o páginas maliciosas?
 - ¿Cuál es su configuración?
 - ¿Qué tipo de páginas o correos se restringen?
 - ¿Quién las administra?
 - ¿Funciona a través de listas blancas o negras? ¿Con qué frecuencia se actualiza?
 - ¿Genera algún tipo de alerta?
 - ¿A quién se les notifica las alertas?
 - ¿Qué actividades se realizan en relación con las alertas?
 - ¿Cómo se documentan dichas actividades?
- d. ¿Se realiza algún tipo de análisis con los correos o URL's maliciosas que detecta la herramienta?
- e. ¿Se ha limitado el uso de lenguajes de scripting en navegadores de internet y clientes de correo electrónico? ¿Cuál es el alcance y a quién aplica dicha limitante?
- f. ¿Se tiene registro de todas las peticiones de URL de cada uno de los sistemas de la empresa?
 - ¿Cómo se registran dichas peticiones?
 - En relación con el registro de dichas peticiones, ¿se utiliza para identificar actividades potencialmente maliciosas y ayudar a los responsables de gestionar incidentes a identificar sistemas potencialmente comprometidos?
 - ¿Qué actividades se realizan en caso de identificar actividades maliciosas?
 - ¿Cómo se documentan dichas actividades?
- g. ¿Se cuenta con servicios de filtrado DNS para el bloqueo de dominios maliciosos? Proporcione evidencia que justifique su respuesta.
 - ¿En qué consisten dichos servicios?
 - ¿Aplica para toda la empresa?
 - ¿En caso de identificar dominios maliciosos se realiza alguna notificación?
 - ¿Quién la recibe?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Qué medidas se toman?
- ¿Cómo se documentan?
- h. ¿Se utiliza el Sandbox para análisis y bloqueo de información adjunta en los correos electrónicos?
- i. ¿Se cuenta con una política de Autenticación, Reporte y Conformidad de mensajes basada en dominio (Domain-based Message Authentication, Reporting and Conformance - DMARC) implementada, así como estándares Sender Policy Framework (SPF) y DomainKeys Identified Mail (DKIM)?

Sobre los controles implementados para la defensa contra malware, especifique lo siguiente:

- a. ¿Como se protege las aplicaciones ante un ataque de croo scripting en las aplicaciones en producción?
- b. ¿Se cuenta con mecanismos de análisis de medios extraíbles que se ejecuten de forma automática cuando éstos se conectan a los equipos de cómputo y/o servidores?
 - ¿En qué consisten?
 - ¿Cuál es su alcance?
 - ¿Aplica para todos los equipos o servidores?
 - ¿Existen excepciones?
 - ¿Cómo se gestionan dichas excepciones?
- c. ¿Cómo se lleva a cabo la actualización de la herramienta antivirus? ¿Con qué frecuencia? ¿Cómo se aseguran de que todos los equipos conectados a la red de la empresa se actualizan?
- d. ¿Se cuenta con mecanismos anti-explotación como la prevención de ejecución de datos (Data Execution Prevention - DEP) o Address Space Layout Randomization (ASLR)? ¿Cuáles son? ¿En qué consisten?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Se ha restringido la ejecución automática de contenido? ¿Cuáles son los mecanismos implementados? ¿Se han aplicado a la totalidad de la infraestructura que se encuentra conectada a la red de la Empresa?
- f. ¿Se han habilitado las bitácoras para registrar el uso de línea de comandos? Proporcione evidencia que soporte sus respuestas.
 - ¿Se han habilitado en todos los equipos?
 - ¿Se considera para los servidores?
 - ¿Quién tiene acceso a dichas bitácoras?
 - ¿Cómo se protegen de modificaciones no autorizadas?
 - ¿Se realizan revisiones a dichas bitácoras? ¿Quién las ejecuta?
 - ¿Qué actividades se realizan en caso de identificar eventos no autorizados?
 - ¿Cómo se documentan?

Sobre la limitación y control de puertos de red, protocolos y servicios, responda lo siguiente:

- a. ¿Se cuenta con mecanismos que permitan asociar puertos, servicios y protocolos activos al inventario de activos?
- b. ¿Como se aseguran de que en cada sistema se ejecuten solo los puertos de red, los protocolos y los servicios que se requieran?
- c. ¿Se realizan escaneos de puertos y con qué periodicidad?
- d. ¿Se cuenta con mecanismos de filtrado de puertos para limitar el tráfico de la red?
- e. ¿Se cuenta con una solución WAF (Web Application Firewall) para el monitoreo de tráfico que va hacia los servidores en producción? ¿Qué herramienta es? ¿Cuál es su alcance?

En relación con la capacidad de recuperación de datos, especifique lo siguiente:

- a. ¿Quién es responsable de prestar el servicio de respaldo a la empresa? ¿Cuál es el alcance de dichos servicios? Proporcione el contrato y el anexo técnico correspondiente a dicho servicio.
 - ¿Cómo se aseguran del cumplimiento de dichos servicios?
 - ¿Cómo se aseguran de que los respaldos generados son suficientes y adecuados?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- b. Describa el proceso de respaldo de información.
 - ¿Se encuentra documentado y formalizado?
 - ¿Cuál es la información que se respalda?
 - ¿Cómo se determinó el alcance de los respaldos?
 - ¿Con qué frecuencia se ejecutan los respaldos de información?
- c. ¿Cómo se protegen los respaldos de seguridad? ¿Se han implementado mecanismos de cifrado para su protección? ¿Cuáles son dichos mecanismos?
- d. ¿En dónde se resguardan los respaldos de la empresa? ¿Cuáles son los mecanismos que se han implementado para restringir el acceso físico a los mismos?

Sobre los controles para una configuración segura de los equipos de red, tales como cortafuegos, enrutadores y conmutadores, responda:

- a. ¿Se cuenta con alguna herramienta que verifique las configuraciones de los equipos de red y detecte los cambios de éstos?
- b. ¿Se cuenta con mecanismos de autenticación multi- factor y sesiones cifradas para los equipos de red? ¿Cuáles son?
- c. ¿Se cuenta con equipos de cómputo dedicados exclusivamente para la ejecución de actividades de administración de la red?

Con relación a los mecanismos con los que se cuenta para la seguridad perimetral, especifique lo siguiente:

- a. ¿Se realizan escaneos desde el exterior del de cada red de confianza para detectar cualquier conexión no autorizada accesible a través del perímetro?
- b. ¿Qué mecanismos se han implementado para denegar la comunicación sobre los puertos TCP o UDP no autorizados o el tráfico de aplicaciones para garantizar que solo los protocolos autorizados puedan cruzar el límite de la red hacia o desde la red, en cada uno de los límites de la red de la empresa?
- c. ¿Se cuenta con un proxy para la seguridad perimetral? ¿para qué servicios es utilizado?
- d. ¿Qué servicios se protegen en la DMZ?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Cuáles son los mecanismos implementados para la autenticación de las conexiones de red?
- f. ¿Cómo se deniegan las comunicaciones mediante IP en los routers?
- g. ¿Cómo se lleva a cabo el monitoreo por medio de IDS e IPS en la red?
¿Cuáles son las reglas configuradas? ¿Se detectaron eventos durante el año en curso? ¿Cómo se atendieron los eventos detectados?

Sobre las actividades con las que se cuenta para la protección de datos, proporcione su respuesta:

- a. ¿Se cuenta con un inventario de información crítica o sensible de la empresa?
- b. ¿Cuenta con una herramienta DLP para el monitoreo de información en la red?
- c. ¿Cuenta con un inventario de los terceros que tienen acceso a servicios en la nube y/o correo electrónico institucional?
- d. ¿Cuenta con una herramienta para el bloqueo de tráfico en caso de detectar transferencia no autorizada de información sensible?
- e. ¿Qué método de cifrado se utiliza para los discos duros de todos los dispositivos?
- f. En caso de permitir el uso de dispositivos de almacenamiento USB ¿Se cuenta de un inventario de dispositivos de almacenamiento USB autorizados para uso exclusivo en la empresa?
- g. ¿Se cifra la información de los dispositivos USB que son autorizados por la empresa? ¿Qué tipo de cifrado se utiliza?
- h. ¿Cómo se aseguran de que la información crítica no puede ser extraída de los dispositivos (estación de trabajo, móviles, Tablet)?

Con relación a la implementación de mecanismos de control de acceso basado en la necesidad de conocer, responda lo siguiente:

- a. ¿Se ha segmentado la red considerando el nivel de clasificación de la información almacenada en los servidores?
- b. ¿Se cifra toda la información sensible en la red institucional? ¿Qué mecanismo de cifrado se utiliza?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- c. ¿Están configuradas las estaciones de trabajo para restringir la comunicación entre ellas?
- d. ¿Se tiene habilitado el filtrado de firewall entre las VLAN para permitir solo la comunicación entre sistemas necesarios y específicos?
- e. ¿Se cuenta con herramientas para el cifrado de información sensible en reposo?

Sobre las actividades para el control de acceso inalámbrico, especifique lo siguiente:

- f. ¿Qué mecanismos de cifrado se utilizan para la información en tránsito en la red inalámbrica?
- a. ¿Cuentan con algún sistema inalámbrico de detección de intrusos (WIDS) para detectar y alertar sobre puntos de acceso inalámbrico no autorizados conectados a la red?
- b. ¿Cuentan con un inventario de los puntos de acceso a nivel nacional actualizado?
- c. ¿Qué tipo de estándar se utiliza para el cifrado de información en las redes inalámbricas?
- d. ¿Qué tipo de protocolos de autenticación son utilizados en sus redes inalámbricas?
- e. ¿Se tiene deshabilitado los accesos periféricos (bluetooth y NFC) en las redes inalámbricas?
- f. ¿Cuentan con una red inalámbrica separada y de diferente segmento para usuarios que no pertenecen a la empresa (¿invitados, proveedores entre otros?)?

En relación con el monitoreo y control de cuentas, responda lo siguiente:

- a. ¿Cuentan con un inventario de los sistemas de autenticación?
- b. ¿Se cuenta con mecanismos de autenticación multifactor para el acceso a todos los sistemas de la empresa?
- c. ¿Qué tipo de cifrado de credenciales de autenticación es utilizado y que alcance tiene?
- d. ¿Cuenta con mecanismos que alerten los inicios de sesión que presentan un comportamiento anormal en los sistemas?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Se ha configurado el bloqueo de las estaciones de trabajo tras pasar por un periodo de inactividad? En caso afirmativo ¿Cómo se aseguran de que la política se aplique a todos los equipos?
- f. ¿Qué políticas se han definido con relación a la vigencia de las cuentas de usuarios en los sistemas?
 - ¿Cuál es el tiempo máximo de vida de las cuentas?
 - ¿Cómo se realiza la configuración de la caducidad de las cuentas?
 - ¿Existen excepciones?
 - ¿Cómo se gestionan dichas excepciones?
 - ¿Se cuenta con algún mecanismo para gestionar de manera centralizada la caducidad de las cuentas de usuario? (p.e. Directorio Activo). En caso contrario ¿Cómo se aseguran de que las políticas son aplicadas a todas las cuentas de usuarios?
- g. ¿Cuentan con un inventario de las cuentas que se eliminan o están desactivadas en la empresa?
 - ¿Quién es el responsable de gestionar y actualizar dicho inventario?
 - ¿Cómo se actualiza y con qué frecuencia?

Sobre las actividades definidas para implementar un programa de concienciación y entrenamiento de seguridad, especifique lo siguiente:

- a. ¿Cuentan con un programa de concientización en materia de seguridad de la información?
- b. ¿Como se verifica el cumplimiento del programa de concientización en materia de seguridad de la información?
- c. ¿Qué criterios son utilizados para la definición de las necesidades del personal en materia de capacitación de seguridad de la información? ¿Cómo se identifican dichas necesidades?
- d. ¿El programa de concientización en materia de seguridad de la información es para todo el personal?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Se considera algún marco de ciberseguridad o cuáles son los fundamentos para definir el programa de concientización de seguridad de la información?
- f. ¿El personal se capacita con base en la clasificación de la información a la que tienen acceso con la finalidad de asegurar la protección de esta?

En relación con la seguridad del software de aplicación, proporcione las siguientes respuestas:

- a. ¿Cuentan con una herramienta autorizada para el escaneo dinámico y estático de código para las aplicaciones en la empresa?
- b. ¿Cómo validan los estándares de seguridad en los aplicativos desarrollados por terceros antes de su adquisición?
- c. ¿El personal del área de desarrollo cuentan con capacitación, así como certificaciones que acrediten su habilidad para escribir código seguro? ¿Cuáles son dichas capacitaciones y certificaciones?
- d. ¿Cuentan con ambientes separados de desarrollo, prueba y producción?
- e. ¿La Empresa cuenta con aplicaciones web? En caso afirmativo ¿Se tiene un firewall de aplicaciones web (WAF) en la empresa?
- f. ¿Se llevan a cabo actividades de hardening para los sistemas e infraestructura de la Empresa?
- g. ¿Se cuenta con plantillas de configuración de hardening estándar para bases de datos?

Sobre las actividades implementadas para la respuesta y manejo de incidentes, responda lo siguiente:

- a. Ante un ataque cibernético ¿Se han definido tiempos de respuesta para asegurar la continuidad del negocio? ¿Cuáles son dichos tiempos? ¿Cuáles han sido los criterios considerados para su definición? ¿Se cuenta con un Análisis de Impacto al Negocio?
- b. ¿Se cuenta con fuentes externas (nacionales e internacionales) para recibir información en materia de seguridad cibernética y prevenir cualquier acontecimiento que pueda afectar a la empresa?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- c. ¿La empresa mantiene comunicación con organizaciones, autoridades, CERT's o algún otro grupo, con la finalidad de notificar vulnerabilidades o incidentes de gran importancia?
- d. ¿Cuáles son los criterios para definir los niveles de criticidad ante un ataque o vulnerabilidad en la infraestructura tecnológica de empresa?
- e. ¿Se realizan pruebas de escenarios de incidentes de seguridad cibernética con los usuarios de la empresa simulando algún evento para verificar tiempos de respuesta?

Con relación a la ejecución de pruebas de penetración y ejercicios de equipo rojo, especifique lo siguiente:

- a. ¿Se cuenta con un programa de pruebas de penetración?
- b. ¿Se llevan a cabo pruebas de equipo rojo para la detección de vulnerabilidades en los sistemas e infraestructura tecnológica?
- c. ¿Se realizan pruebas de presencia de información y artefactos no protegidos?
- d. ¿Cuentan con un banco de pruebas para elementos que normalmente no se realizan en sistemas de producción?